

# Статья Харденинг Active Directory глазами атакующего: Protected Users, Tiering Model и LAPS на внутреннем пентесте

 [codeby.net/threads/khardening-active-directory-glazami-atakuyushchego-protected-users-tiering-model-i-laps-na-vnutrennem-penteste.93653](https://codeby.net/threads/khardening-active-directory-glazami-atakuyushchego-protected-users-tiering-model-i-laps-na-vnutrennem-penteste.93653)

May 15, 2026

[Добавить закладку](#)



Три недели назад на внутреннем пентесте банковской инфраструктуры мы получили Domain Admin за 47 минут. Цепочка банальная до предела: Responder в пользовательском VLAN, NTLMv2-хеш сервисной учётки через LLMNR poisoning (T1557.001), hashcat, lateral movement через CrackMapExec с общим паролем локального админа - Pass the Hash (T1550.002) на каждую рабочую станцию, дампы LSASS, DA-хеш, DCSync. На следующем проекте - примерно тот же масштаб, тот же стек Windows Server - на четвёртый день мы всё ещё собирали BloodHound-граф в поисках хоть какого-то пути до Tier 0. Разница не в бюджете на EDR. Разница - Protected Users, Active Directory Tiering Model и LAPS. Три меры, которые превращают харденинг Active Directory из бумажной рекомендации в реальную головную боль для атакующего.

По данным IBM X-Force Threat Intelligence Index 2025, рост атак с использованием действительных учётных данных (Valid Accounts, T1078) - 71% год к году. CrowdStrike

Global Threat Report 2025 подтверждает: 75% вторжений в 2024 году опирались на валидные креды, а среднее время lateral movement после initial access - 62 минуты. Credential-based атаки - основной вектор. И именно на них должен быть сфокусирован харденинг.

Ниже - разбор каждой из трёх мер с позиции атакующего: что она ломает в стандартной цепочке, как проверить её наличие из grey box и какие Event ID выдают вас в SIEM.

### Выбор вектора атаки: decision tree для пентеста Active Directory

Первые 15 минут внутреннего пентеста определяют стратегию. Вот что стоит проверить до запуска первого инструмента - и как результат меняет вектор. Подробнее - в нашем [подробном разборе пентест active directory](#).

| Условие                  | Если не внедрено                                                    | Если внедрено                                                | Вектор при обходе                                                      |
|--------------------------|---------------------------------------------------------------------|--------------------------------------------------------------|------------------------------------------------------------------------|
| LLMNR/NBT-NS активен     | Responder → NTLMv2-хеш → hashcat / relay (T1557.001)                | Responder молчит, переходи к другим векторам                 | IPv6 poisoning (mitm6), если IPv6 не отключён                          |
| LAPS не развёрнут        | Один хеш локального админа → PtH по всем хостам (T1550.002)         | Каждый хост с уникальным паролем, PtH латерально не работает | Проверь ACL на атрибут ms-Mcs-AdmPwd - чтение может быть не ограничено |
| Protected Users пуст     | Kerberoasting, AS-REP Roasting, NTLM relay привилегированных учёток | NTLM отключён для этих учёток, TGT 4 часа, RC4 недоступен    | Ищи привилегированные учётки, которые НЕ в Protected Users             |
| Tiering Model не внедрён | DA логинится на рабочую станцию → дамп LSASS → DA creds             | Логон DA ограничен GPO до DC/PAW, на станциях его кредов нет | Ищи Tier 0-системы вне DC: SCCM, Azure AD Connect, PAM-серверы         |

**Контекст применимости:** таблица работает для внутреннего пентеста в grey box (есть доменная учётка уровня Domain User) или black box (получен initial access через физическое подключение к VLAN). Для внешнего пентеста эти меры неактуальны до момента закрепления внутри периметра.

## Fingerprinting защиты Active Directory из grey box

---

### Требования к окружению:

 Часть контента скрыта. Этот материал доступен участникам сообщества с рангом [One Level или выше](#)

Получить доступ просто — достаточно проявить активность на форуме

Нюанс, который часто упускают (описан на [radioactivedirectory.com](http://radioactivedirectory.com)): НЕ добавляйте в Protected Users компьютерные учётки - сломаете аутентификацию хоста. И НЕ добавляйте KRBTGT - он защищён иначе. Флаг «Account is sensitive and cannot be delegated» полностью избыточен для учётки в Protected Users: группа уже блокирует delegation на уровне KDC.

## Active Directory Tiering Model: Tier 0, Tier 1, Tier 2 и lateral movement

---

Tiering Model - разделение среды AD на три уровня с жёсткими ограничениями на логон между ними. Для атакующего суть простая: компрометация рабочей станции пользователя (Tier 2) больше не даёт прямого пути к Domain Admin (Tier 0).

### Как ломается стандартная цепочка атаки без tiering

---

Классический сценарий внутреннего пентеста, который я наблюдаю раз за разом:

1. Initial access через phishing или физическое подключение → Tier 2
2. Дамп LSASS на скомпрометированной рабочей станции
3. В дампе - хеш Domain Admin, который «на минутку» логинился на эту станцию
4. Pass the Hash на DC → DCSync → полный контроль

Шаг 3 возможен только потому, что DA логинится на машину Tier 2. Tiering Model убирает этот шаг через GPO: Deny log on locally, Deny log on through Remote Desktop Services, Deny access to this computer from the network для DA/EA на всех машинах, кроме DC и Privileged Access Workstation (PAW). Путь GPO: Computer Configuration → Windows Settings → Security Settings → Local Policies → User Rights Assignment.

### Что является Tier 0 помимо контроллеров домена

---

Согласно данным [radioactivedirectory.com](http://radioactivedirectory.com), Tier 0 - не только DC. И вот тут начинается самое интересное - часто упускаемые системы:

- Серверы резервного копирования с задачами бэкапа DC - восстановление бэкапа DC = владение доменом. Про это забывают почти всегда.
- Azure AD Connect / Entra ID Connect - синхронизация кредов с облаком.
- SCCM, если может пушить пакеты на DC - выполнение кода на DC через deployment. На одном проекте именно через SCCM я и зашёл, когда прямой путь был закрыт.
- ПАМ-серверы (CyberArk, BeyondTrust, Delinea), хранящие DA-креды - компрометация vault'a = все DA-пароли разом.
- IGA-платформы (SailPoint, Saviynt), которые могут создавать DA-учётки.

На пентесте запустите BloodHound с --CollectionMethods All и ищите Shortest Path to Domain Admins. Часто обнаруживаются пути через Tier 1-системы, которые фактически являются Tier 0, но не были классифицированы как таковые.

### Где tiering неполный: типичные находки на пентестах

---

По опыту, полный Tiering Model - редкость. Вот что я нахожу регулярно:

- Сервисные учётки с DA-правами на Tier 1-серверах. Одна скомпрометированная учётка сервиса на веб-сервере = DA. Проверка: Get-ADGroupMember "Domain Admins" -Recursive - перекрёстно сравните каждого DA с учётками, имеющими SPN (сервисные учётки = Kerberoasting target).
- Администраторы с одной учёткой для всех уровней. GPO запрещает DA-логон на станции, но «admin\_ivanov» в обычных группах имеет DCSync-права через ACL - и используется повсеместно. По документам - tiering внедрён. На практике - дыра размером с ворота.
- Jump-серверы без MFA - RDP-сессии к DC доступны любому серверному админу. Формально jump-сервер есть, по факту - просто прокси без защиты.

**Контекст:** Tiering Model актуален для корпоративных AD от 100+ хостов. В мелких средах формальный tiering избыточен, но принцип «DA не логинится на рабочие станции» обязателен в любом масштабе.

### LAPS настройка и аудит: конец одинаковых паролей локального админа

---

Без LAPS пароль локального администратора одинаков на всех рабочих станциях - задаётся через образ или, что хуже, через Group Policy Preferences (GPP). Напомню: 32-байтный AES-ключ для расшифровки GPP cpassword опубликован Microsoft в спецификации [MS-GPPREF] §2.2.1.1.4 - шифрование бесполезно. MS14-025 запретил создание новых GPP-паролей, но уже существующие cpassword в SYSVOL остаются расшифровываемыми любым доменным пользователем. Один перехваченный хеш через PtH (T1550.002) открывает доступ к каждой машине в домене.

LAPS генерирует уникальный пароль локального админа на каждом хосте, ротирует его по расписанию и хранит в атрибуте ms-Mcs-AdmPwd

### **ACL-мисконфигурации: когда LAPS не спасает**

---

LAPS развёрнут - отлично. А кто может читать пароли? Проверьте ACL на каждом OU:

```
(Get-ACL "AD:\OU=Workstations,DC=domain,DC=com").Access | Where-Object {  
$[I].ActiveDirectoryRights -match "ReadProperty" -and $[I].ObjectType -eq  
"ms-Mcs-AdmPwd" } | Select-Object IdentityReference
```

Если в списке - группа шире dedicated helpdesk-группы (например, Domain Users или все Tier 1-админы), атакующий с low-priv учёткой может читать LAPS-пароли всех машин в OU. На практике это превращает LAPS из защиты в удобный справочник паролей. Я такое видел не раз - LAPS развёрнут, ACL не настроен, и любой доменный юзер тупо читает пароли локальных админов через LDAP.

### **Windows LAPS vs Legacy LAPS**

---

Начиная с Windows Server 2019 (и особенно в 2022) Microsoft включила Windows LAPS нативно в ОС. Ключевое отличие для атакующего: пароль в AD может быть зашифрован ключом, доступным только авторизованным принципалам. Шифрование паролей требует DFL 2016+ и наличия KDS root key в домене (тот же, что используется для gMSA); без KDS root key шифрование не запустится. Без encryption Windows LAPS работает на любом поддерживаемом DFL, но пароль хранится в plaintext, как и в Legacy LAPS. Также поддерживается история паролей и интеграция с Azure AD. Если заказчик на Windows LAPS с шифрованием - простое чтение атрибута уже не работает.

Для проверки покрытия Windows LAPS: `Get-LapsADPassword -Identity "WORKSTATION01" -AsPlainText` - если команда возвращает пароль, значит у вашей учётки есть доступ; если нет - ACL настроен корректно.

### **Детектирование атак Active Directory через Event Log и мониторинг AD через SIEM**

---

Каждая техника, описанная выше, оставляет следы в Windows Event Log. Вопрос - настроен ли SIEM на их обработку и понимает ли SOC-команда, что она видит.

## Ключевые Event ID для мониторинга AD-атак

| Event ID | Источник        | Что детектирует                                                                                                                                                                                                                                                                   | OPSEC-значение для атакующего                               |
|----------|-----------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------|
| 4768     | Security (DC)   | TGT request - AS-REP Roasting виден по RC4-запросам от учётки без pre-auth                                                                                                                                                                                                        | Высокое: RC4-запрос для Protected Users - мгновенный alert  |
| 4769     | Security (DC)   | Service ticket - Kerberoasting виден по массовым TGS с RC4                                                                                                                                                                                                                        | Среднее: единичный запрос нормален, массовые - аномалия     |
| 4624     | Security (хост) | Logon Type 9 (NewCredentials) - паттерн Pth через Mimikatz sekurlsa: <br>th / runas /netonly. Impacket (psexec.py, wmiexec.py) генерирует Type 3 (Network) с NTLM - требует отдельной корреляции | Низкое: массовый поток, нужна корреляция                    |
| 4776     | Security (DC)   | NTLM validation - всплеск от одного источника = relay-индикатор                                                                                                                                                                                                                   | Среднее: Protected Users + NTLM = код ошибки → alert        |
| 4662     | Security (DC)   | Object access - DCSync по обращению к <a href="#">DS-Replication-Get-Changes</a>                                                                                                                                                                                                  | Высокое: DCSync от non-DC - один из самых надёжных детектов |

## [Sigma-правила из SigmaHQ](#)

Из репозитория SigmaHQ доступны готовые правила под конкретные техники:

- **Pass the Hash (T1550.002):** win\_security\_potential\_pass\_the\_hash.yml и win\_security\_pass\_the\_hash\_2.yml - Event 4624 Type 9 с LogonProcess seclogo
- **LLMNR Poisoning (T1557.001):** driver\_load\_win\_windivert.yml - загрузка WinDivert-драйвера, используемого Inveigh
- **PetitPotam / Forced Authentication (T1187):** win\_security\_petitpotam\_network\_share.yml и zeek\_dce\_rpc\_potential\_petit\_potam\_efs\_rpc\_call.yml - DCE/RPC-детект

Пример Sigma-правила для PtH (адаптировано из SigmaHQ):

```
title: Potential Pass the Hash Activity
logsource:
  product: windows
  service: security
detection:
  selection:
    EventID: 4624
    LogonType: 9
    LogonProcessName: 'seclogo'
    AuthenticationPackageName: 'Negotiate'
  condition: selection
level: medium
```

Правило срабатывает на Event 4624 Type 9 с процессом seclogo - типичный паттерн PtH через sekurlsa::pth (Mimikatz) или Impacket. Конвертируется в запрос Splunk или Microsoft Sentinel через sigma-cli. **Ограничение:** даёт false positive при легитимном runas /netonly. В средах с AD FS и SSO-сценариями - требуется тюнинг whitelist'a.

### OPSEC: как атакующему остаться тише в захарденной среде

---

- RC4-запросы в среде с Protected Users - если все привилегированные учётки в AES-only, любой RC4-запрос к KDC попадёт в корреляцию. Kerberoasting через AES генерирует меньше шума, но тикеты на порядки сложнее ломать. Палка о двух концах.
- NTLM для DA - попытка NTLM-auth для учётки из Protected Users сгенерирует Event 4776 с кодом ошибки. Прямой alert в любом настроенном SIEM. Если SOC не спит - вас заметят.
- BloodHound - массовые LDAP-запросы не триггерят стандартные правила, но продвинутые SIEM (Microsoft Sentinel с UBA, Splunk ES) коррелируют объём запросов от одного источника. Вариант тише - --CollectionMethods DCOnly.
- DCSync - Event 4662 с обращением к DS-Replication-Get-Changes-All от non-DC источника. Обойти нативными средствами Windows невозможно; единственный путь - компрометация SIEM или очистка логов. Ни то, ни другое не назовёшь элегантным решением.

### Чеклист харденинга Active Directory для отчёта по пентесту

---

Каждый пункт - конкретное действие. Формат пригоден для передачи сисадмину или включения в приложение к отчёту.

#### Приоритет 1 - закрывает основные credential-based векторы:

- Все учётки DA, EA, Schema Admins добавлены в Protected Users

- [LAPS развёрнут на всех рабочих станциях](#) и серверах (проверка покрытия: Get-ADComputer -Filter \* -Properties ms-Mcs-AdmPwd)
- LLMNR отключён через GPO (ключ EnableMulticast = 0 в HKLM\Software\Policies\Microsoft\Windows NT\DNSClient)
- NBT-NS отключён через NodeType = 2 (HKLM\SYSTEM\CurrentControlSet\Services\NetBT\Parameters)
- GPO User Rights Assignment: Deny logon locally / Deny RDP / Deny network access для DA/EA на всех non-DC/PAW хостах

### **Приоритет 2 - закрывает lateral movement:**

- ACL на ms-Mcs-AdmPwd ограничен dedicated группой, не Domain Users
- Сервисные учётки удалены из Domain Admins, заменены на gMSA
- Unconstrained delegation только на DC (PrimaryGroupID 516)
- AS-REP Roastable учётки: 0
- Credential Guard включён на Windows 10+ / Server 2016+

### **Приоритет 3 - мониторинг и детект:**

- Аудит Event ID 4768, 4769, 4624, 4776, 4662 включён на всех DC
- Sigma-правила для PtH и DCSync импортированы в SIEM
- Алерт на NTLM-аутентификацию для учётки из Protected Users
- Регулярный (раз в квартал) запуск BloodHound для поиска новых путей к Tier 0

Из десятков внутренних пентестов AD за последние два года я наблюдаю устойчивый паттерн: организации покупают EDR и SIEM, не внедрив базовые бесплатные меры. EDR исправно детектирует Mimikatz - молодец, - но DA-хеш уже лежит в LSASS рабочей станции бухгалтера, потому что администратор логинился «на минутку посмотреть принтер». Tiering Model стоит ноль рублей и требует только GPO, но его не внедряют, потому что сисадминам «неудобно» держать отдельные учётки. Protected Users не включают, потому что «а вдруг что-то сломается» - и не тестируют даже на пилотной группе. В итоге привилегированный доступ Active Directory защищён формально, а реальный путь от пользовательского VLAN до DCSync укладывается в обеденный перерыв. По опыту, организация, внедрившая хотя бы Приоритет 1 из чеклиста выше, увеличивает время пентеста с дней до недель - и это без единого нового продукта в стеке. Если хочешь отработать AD-цепочку от ресон до DCSync на стенде без корпоративного EDR - на HackerLab.pro есть задачи именно с этой спецификой.